

SECURITY ASSESSMENT DOCUMENT (SAD)

Reference Template for Document Validation System

1. Introduction

1.1 Purpose

Describe the purpose of this Security Assessment Document (SAD). Mention the system name and explain what security behaviors, vulnerabilities, and risk evaluations this document is intended to define.

1.2 Scope

Describe the scope of the security assessment. Explain which systems, networks, applications, and features are included and what is not covered by this document.

1.3 Definitions, Acronyms, and Abbreviations

List important terms, acronyms, and abbreviations used in the document.

Term	Description
SAD	Security Assessment Document
Vulnerability	A weakness which can be exploited by a threat actor
Mitigation	An action taken to reduce a security risk

1.4 References

List any documents, standards, or resources referred to when preparing this SAD, such as threat models, compliance frameworks (OWASP, ISO 27001), or project guidelines.

1.5 Document Overview

Briefly explain how the rest of the document is organized.

2. Security Overview

2.1 System Functions

List the main security-sensitive functions of the system.

- User authentication and authorization mechanisms
- Data encryption in transit and at rest
- Threat detection and logging systems
- Boundary defense and firewall configurations
- Access control management

2.2 User Classes and Characteristics

Describe the different types of users/actors who interface with the system's security boundaries.

- Security Administrator
- Internal Auditor
- Authorized End-User
- Guest User

2.3 Operating Environment

Describe the hardware, software, cloud infrastructure, network topology, or operating system environment required to run and secure the system.

3. Security Requirements

3.1 Detailed Functional Requirements

Describe each security control the system must perform, with a unique identifier and priority.

Requirement ID	Description	Priority
SEC-01	The system shall enforce multi-factor authentication (MFA) for administrative access.	High
SEC-02	The system shall encrypt all sensitive user data at rest using AES-256.	High
SEC-03	The system shall automatically terminate user sessions after 15 minutes of inactivity.	High
SEC-04	The system shall log all failed login attempts with timestamps and IP addresses.	High
SEC-05	The system shall restrict API access to validated API keys and tokens.	High
SEC-06	The system shall undergo automated vulnerability scans on a weekly basis.	Medium
SEC-07	The system shall mask payment card information on all display interfaces.	Medium

4. External Interface Requirements

4.1 User Interface Requirements

Describe the user interface security requirements of the system.

- The system shall provide secure login interfaces masking password inputs.
- The system shall display clear, generic error messages for authentication failures without revealing system details.
- The system shall show a security warning banner upon access to the admin portal.

4.2 Software Interface Requirements

Describe software components, APIs, databases, or external services used by the system.

- The system may use an Identity Provider (IdP) for Single Sign-On (SSO) integration.
- The system may use a Centralized Logging Service (SIEM) to analyze security events.
- The system may use a Hardware Security Module (HSM) to manage cryptographic keys.

5. Business Rules

5.1 Rules and Constraints

Define the business rules and security compliance logic that the system must enforce.

- Only users with an explicit "Admin" role can view system security audit logs.
- Passwords must meet specific complexity metrics (minimum length, special characters).
- IP addresses exhibiting brute-force characteristics must be automatically throttled.
- The severity score of a vulnerability determines its remediation deadline.

6. Non-Functional Requirements

6.1 Performance Requirements

- The system shall authenticate user credentials and generate tokens within an acceptable response time.
- The system shall handle logging traffic without causing latency to the primary application features.

6.2 Security Requirements

- The system shall allow only authorized security personnel to clear audit trails.
- All backup files shall be stored in an off-site, encrypted environment.
- User passwords shall be hashed using a strong cryptographic algorithm (e.g., bcrypt).

6.3 Usability Requirements

- The security setup process (e.g., MFA enrollment) shall provide a user-friendly interface.
- Security alert configurations shall be easy to understand for administrators.

7. Validation Rules

7.1 Required Sections

The uploaded SAD document should include the following main sections:

- Introduction
- Security Overview
- Security Requirements
- External Interface Requirements
- Business Rules
- Non-Functional Requirements
- Validation Rules

- Appendices

7.2 Validation Criteria

The document validation system should check:

- Whether required sections are available
- Whether section names are similar to the SAD template
- Whether sections follow the correct order
- Whether unrelated extra sections are included
- Whether the document belongs to the correct document type

7.3 Scoring Criteria

Score Range	Validation Result
75-100	Accept
50-74	Needs Improvement
0-49	Reject

8. Appendices

8.1 Appendix A: Functional Use Cases

Insert detailed threat vectors, attack tree scenarios, or security architecture diagrams if available.

8.2 Appendix B: Additional Information

Include any extra information or compliance mappings related to the system.